SOC·L2 · Nordic Shadow Hunter — Análisis Forense SIEM

Informe de síntesis del proyecto · Bootcamp Analista SOC Nivel 2, reto final

Autor: Sebastian Szostak · Fecha: 8 de noviembre de 2026

1. Objetivo

El cliente (un operador esencial del sector energético) entregó un archivo Excel con registros exportados de su SIEM y reportó un posible incidente. La herramienta debe validar e ingerir la telemetría, extraer indicadores de compromiso (IoCs), correlacionar eventos para determinar si hubo uno o varios incidentes independientes y generar un informe forense ejecutivo y técnico en PDF. Además, cumple una regla estricta de rigor forense («evidencia antes que intuición»): ninguna conclusión puede carecer de respaldo en los registros (Log_ID), la severidad original del SIEM no se asume como verdadera y cuando la telemetría no alcanza para corroborar un impacto se declara explícitamente como «no confirmado».

2. Arquitectura

La solución está escrita en Python con arquitectura modular desacoplada entre el motor analítico, la interfaz interactiva en Streamlit (app.py), el generador documental PDF y las reglas equivalentes para Microsoft Sentinel. El flujo del analista recorre seis módulos (Resumen, Incidentes, Threat Hunting, IoCs, Calidad de datos e Informe PDF) respaldados por cinco componentes técnicos:

- **Ingesta y validación (app.py, detections.py).** Verifica el esquema de 12 columnas de la hoja «SIEM Export», calcula el resumen criptográfico SHA-256 en tiempo real sobre los bytes del archivo y normaliza marcas temporales, Event_ID, IPs públicas/privadas (is_external_ip), LogonType y volumen saliente (bytes_out).
- **Detección determinista (detections.py).** Evalúa 14 reglas auditables (R1 a R14) basadas en umbrales y ventanas temporales sin entidades hardcodeadas: password spraying, fuerza bruta RDP, cuenta comprometida, privilegios especiales (4672), LOLBins/PowerShell/vssadmin, movimiento lateral RDP/SMB, acceso a recursos sensibles, enumeración masiva, posible exfiltración por proxy/C2, persistencia, beaconing periódico, web shell y calidad de datos (R14).
- **Correlación, IoCs y mapeo MITRE ATT&CK.** Agrupa los eventos maliciosos en 6 incidentes independientes (INC-01 a INC-06), recalcula la severidad analítica (Severidad_SOC: Alto, Medio, Bajo), mapea tácticas y técnicas MITRE ATT&CK v14 y extrae una tabla estructurada de IoCs diferenciando cuentas comprometidas de cuentas únicamente atacadas.
- **Informe forense PDF (report.py, report_content.py) y consultas Sentinel (kql/).** Genera con fpdf2 un informe de 21 páginas dividido en Resumen Ejecutivo (impacto NIS2/RGPD, matriz de riesgo) y Resumen Técnico (cronología por Log_ID, MITRE, IoCs, atribución ACH, brechas y playbooks), complementado con 13 consultas KQL (R01 a R13) y una suite pytest de 7 pruebas sobre el ground truth de 121 Log_ID (tests/test_detections.py).

La capa de IA generativa es opcional: si existe la variable de entorno GEMINI_API_KEY, el módulo Resumen habilita una síntesis ejecutiva con Gemini a partir de los KPIs y títulos de incidentes ya calculados por las reglas (nunca recibe el Excel crudo). Si no se configura clave o la consulta falla, toda la consola y el PDF operan íntegramente con el motor determinista.

3. Datos de entrada y de salida

Sección	Detalle
Entrada	Excel .xlsx, hoja «SIEM Export», 715 registros del 2026-10-23 (07:46:07 a 13:44:06), con 12 columnas: Log_ID, Timestamp, Hostname, Event_ID, User, Source_IP, Destination, Log_Source, Event_Description, Process_CommandLine, Result y Severity. SHA-256 verificado: f645d76800097c09f3102d7d4f1cb5c1b2bb286d6cd054ab3daabe62c69d85f0.
Resultado del análisis	121 eventos asignados a 6 incidentes correlacionados (Severidad_SOC: 48 en Alto y 73 en Medio) sobre 7 hosts afectados (DC-01, APP-SRV01, FS-SRV01, WEB-01, WS-018, WS-023, WS-031) y 5 IPs externas: INC-01 (35 eventos), INC-02 (15), INC-03 (18), INC-04 (24), INC-05 (7) e INC-06 (22), más anomalías de calidad de datos (R14, severidad Bajo) separadas de los incidentes.
Salida	Informe forense PDF de 21 páginas (sample_report.pdf) estructurado en Parte 1 (Resumen Ejecutivo, impacto en el negocio, cumplimiento RGPD/NIS2, prioridades P1–P5 y matriz de riesgo) y Parte 2 (metodología, incidentes, línea de tiempo por Log_ID, matriz MITRE, IoCs, atribución ACH, brechas de visibilidad, playbooks de contención y Anexos A–B), junto con exportación CSV en la consola.

En cuanto a los hallazgos por incidente: INC-01 (35 eventos) es un password spraying desde 203.0.113.74 contra 8 cuentas, seguido del inicio de sesión exitoso de CORP\mgarcia en WS-031 con privilegios especiales (Event_ID 4672). INC-02 (15 eventos) encadena fuerza bruta RDP desde 198.51.100.77 sobre CORP\admin en APP-SRV01, reconocimiento con PowerShell codificado, movimiento lateral SMB hacia FS-SRV01 (recurso Finance), compresión local y conexión saliente hacia 203.0.113.88:443 (posible exfiltración no confirmada). INC-03 (18 eventos) registra enumeración masiva con CORP\backupsvc en FS-SRV01 y WS-023 seguida del borrado de copias shadow (vssadmin delete shadows /all /quiet). INC-04 (24 eventos) involucra a CORP\rrojas en WS-018 comprimiendo archivos de \FS-SRV01\Legal con 7z.exe y generando solicitudes HTTP POST vía proxy hacia 198.51.100.88 con un volumen saliente registrado (bytes_out) de 253.305.558 bytes (~253 MB, posible exfiltración no confirmada). INC-05 (7 eventos) evidencia persistencia en APP-SRV01 (CORP\helpdesk) mediante la tarea \Microsoft\Windows\UpdateCheck, el servicio WinUpdateHelper y ejecuciones de wuhelper.exe cada 6 minutos. Por último, INC-06 (22 eventos) combina sondeo web desde 192.0.2.91 sobre WEB-01 con ejecución de comandos vía web shell test.aspx bajo IIS APPPOOL\DefaultAppPool.

4. Correcciones durante el desarrollo

Durante las iteraciones de desarrollo y auditoría del proyecto se aplicaron cuatro correcciones respaldadas en el historial de commits de Git:

- **Precisión forense de IoCs, IPs de contención y alineación del Anexo A (commits b25fb9e y 4d20f88).** Se depuró la tabla de IoCs para distinguir cuentas comprometidas de cuentas únicamente atacadas, se ajustaron las reglas de bloqueo de los playbooks a las IPs reales de cada incidente y se alineó la tabla de umbrales del Anexo A del PDF con las constantes efectivas de detections.py.
- **Tema claro/oscuro/sistema, gráfico temporal y verificación SHA-256 real (commits 1a3ee99 y 0c7160b).** Se reemplazaron los estilos fijos por contenedores nativos adaptables al tema de Streamlit, se restauró el histograma temporal de actividad maliciosa en intervalos de 5 minutos y se implementó el cálculo real del hash SHA-256 sobre los bytes cargados para contrastarlo con el digest oficial del dataset.
- **Eje temporal navegable en gráficos interactivos Plotly (commit e118c54).** Se añadieron controles rangeslider, botones de escala rápida (15 min, 30 min, 1 h, Todo) y zoom con rueda del ratón (scrollZoom) en los gráficos temporales de Resumen, Incidentes y Threat Hunting.
- **Rigor en volumen saliente y exfiltración no confirmada (commits 4f0129d y faea98d).** Se eliminó de report_content.py, report.py, app.py, detections.py y README.md el lenguaje que afirmaba exfiltración confirmada. El KPI y los textos pasaron a informar «Volumen saliente registrado (bytes_out)» (253.305.558 bytes, ~253 MB en INC-04) y la exfiltración quedó declarada como no confirmada con el SIEM.

5. Limitaciones

El análisis se basa solo en registros exportados del SIEM en una ventana de aproximadamente seis horas (07:46:07 a 13:44:06), sin captura de red (PCAP), sin logs de firewall perimetral o VPN, sin eventos Kerberos (4768/4769) ni de credenciales explícitas (4648) y sin telemetría EDR/Sysmon (ausencia de Sysmon Event ID 1 con hashes SHA-256/MD5 y de Event ID 10 sobre lsass.exe). Además, las 5 IPs externas pertenecen a rangos de documentación RFC 5737 (reputación no verificable en CTI/MISP), existen comandos PowerShell ofuscados con -EncodedCommand y hay nombres de host y cuentas inconsistentes (DC-01 vs. DC01 y CORP\backupsvc vs. CORP\svc_backup). Por tanto, el éxito de la exfiltración queda como no confirmado.

6. Presentación y repositorio

El video demostrativo dura un máximo de cinco minutos y sigue el orden: arquitectura y estado inicial, carga del Excel y SHA-256, Resumen y KPIs, Incidentes con cadena MITRE ATT&CK, Threat Hunting con filtros, IoCs y Calidad de datos (R14), descarga y apertura del PDF de 21 páginas y cierre sobre limitaciones y la regla de exfiltración no confirmada. El repositorio de GitHub contiene detections.py, app.py, report.py, report_content.py, kql/, tests/test_detections.py, sample_report.pdf y docs/. La API key de Gemini no se incluye en el código.

- **Video demostrativo:**
  https://youtu.be/X1NJu_VQ_mg
- **Repositorio en GitHub:**
  https://github.com/Szastak/Proyecto-SOC2
- **Informe técnico forense (PDF, 21 páginas):**
  sample_report.pdf (https://github.com/Szastak/Proyecto-SOC2/blob/main/sample_report.pdf)
- **Informe de síntesis del proyecto final (PDF, 2 páginas):**
  docs/Informe_Proyecto_Final.pdf (https://github.com/Szastak/Proyecto-SOC2/blob/main/docs/Informe_Proyecto_Final.pdf)